

PhishWise: An Interactive Phishing Awareness Learning Activity

COMP6441 / COMP6841 Security Engineering

Category A: Teach Something

Final Project Report

Abstract

This project developed a set of phishing identification and protection learning activities, primarily targeting university students who regularly use school email and learning platforms but rarely engage in cybersecurity courses. The project integrates knowledge explanation, scenario exercises, and learning assessments onto a single local webpage. Learners first complete a pre-test, then read eight learning topics, subsequently examine three fictitious emails, and complete seven security response judgments. The activity concludes with a post-test, a results page, and a feedback form. The webpage also offers Chinese and foreign language options, with corresponding questions, prompts, and scenarios in both languages.

This assignment focuses on the teaching process and security analysis; the webpage is merely a tool for delivering content. Starting with protected objects such as accounts, credentials, sessions, and data, the project analyzes how attackers exploit sender identities, links, attachments, and login pages, integrating personal judgment, technical controls, and organizational responses within a unified protection framework. Current functional checks are complete; real participant testing will be conducted in the next phase. Scores in classroom demonstrations are provisional examples; formal learning outcomes will be supported by pre- and post-tests and feedback from real participants.

1. Project Background and Assignment Requirements

The first type of project in the Security Engineering course requires students to create instructional activities or case studies that teach security concepts to a defined student group. Assignments also focus on the project process; students need to explain how their security understanding changes, how they handle problems encountered, and how the project evolves from its initial draft. Real-participant testing is also part of the requirements; the activity needs to be actually used and document evidence demonstrating its effectiveness.

Phishing is suitable for beginners because university students encounter emails, school portals, and shared files daily. Attackers often use familiar names, urgent notifications, and login requests to gain trust-content that aligns with students' daily habits. The project links common warnings with attack objectives; learners need to identify suspicious locations and explain the methods for checking and the security procedures, thus transforming general reminders into concrete exercises.

This project has been developed into a locally run interactive activity. The target audience, learning objectives, and security scope are explained on the start page. Website functionality only indicates that the activity is usable; the effectiveness of the teaching is judged through the paired scores of real participants, scenario performance, and anonymous feedback. Therefore, the test arrangements and blank record templates are also part of the project materials.

2. Target Audience and Learning Objectives

The primary target audience is university students aged 18 and above who frequently use school email or learning platforms. They have general experience with web pages and email, but limited experience with cybersecurity courses. Cybersecurity students and professionals can help verify the accuracy of the knowledge; their basic level differs from beginners, and the official sample will record the two groups separately.

The activity sets five main learning objectives. Learners must first distinguish between display names, complete sender addresses, and reply addresses, then identify links based on main domains, subdomains, and similar spellings. Next, they need to identify psychological manipulation techniques such as urgency, fear, authority, reward, and familiarity, and check attachment types and login pages. Exercises also require learners to choose action steps after accidentally clicking links, revealing passwords, or opening attachments. Finally, they understand that comprehensive protection requires the joint efforts of individuals, technology, and organizations.

For ease of measurement, both the pre-test and post-test have ten questions, each corresponding to a knowledge topic. The ten topics include sender identity, domains and subdomains, limitations of encrypted connections, social engineering, suspicious attachments, fake login pages, the role of multi-factor authentication, post-click handling, handling of credential leaks, and independent verification and incident reporting. The two sets of questions use different scenarios and wording; this arrangement reduces the impact of memorizing the original answers.

3. Eight Steps of the Website

The first section, "Getting Started," explains the activity's purpose, estimated time, and learning direction. Learners will first see three skill sets: identification, analysis, and response. The page also identifies the primary audience and provides a brief explanation of the local operation and security scope. The educational purpose here is to establish the task context, letting learners know what they need to master before even entering the questions.

The second section, "Pre-Test," consists of ten multiple-choice questions, each offering three or four somewhat misleading options. These questions are placed before the learning modules. Upon submission, the system checks completion, providing hints for missed answers. After complete submission, the system only records the total score and performance on each topic; correct answers are processed later in the learning and results phase. The pre-test serves as a starting point and provides a basis for comparison in the post-test.

The third section, "Learning," uses eight collapsible topics that learners can expand as needed. Each topic explains the attacker's objectives, common practices, observable signals, reasons for the techniques' effectiveness, personal handling methods, and organizational control, while also providing hypothetical examples. The folded structure divides long content into smaller sections, and the page also uses step-by-step diagrams, comparison boxes, and hint cards to allow beginners to read in segments.

The fourth section, "Check," presents three fictitious emails: an impending account expiration, a scholarship or refund notification, and a tutor or shared file notification. Each email has seven clickable locations, including the display name, full address, reply address, urgent wording, link text, actual domain name, and attachment or data request. After a learner clicks on a location, the right side displays warning signs, the purpose of the attack, the reason for the deception, verification

methods, and corresponding controls. Upon completion of the scenario, the page displays the score and any missing locations.

The fifth section, "Defense," retains the four core steps of pausing, checking, independent verification, and reporting, followed by seven response scenarios. Scenarios begin with receiving a suspicious email and gradually progress to situations where the link has been opened, the password has been submitted, the attachment has been opened, and an unknown login request has been approved. Later scenarios include situations where the email's authenticity is difficult to determine, and situations where the organization discovers multiple people have received the same email. Each question has three options; after selecting an option, learners immediately see the correct reason, the risks of other options, their personal next steps, and the organization's next steps.

The post-test also includes ten multiple-choice questions, covering the same knowledge objectives as the pre-test, but using a different set of scenarios. The completeness check before submission is the same as the pre-test; after completing the test, the system records the total score and the answers for each topic. The post-test primarily checks whether learners can apply what they have just learned to new expressions.

The results page displays the pre-test score, post-test score, and score changes together, and also shows the scores for the three email inspection scenarios and the defense practice results. The page lists mastery levels by ten knowledge topics and recommends returning to the corresponding learning section based on incorrect topics. Official records remain in the browser session storage area; learners can also clear local results. Anonymous abstracts used for research only include scores and question results; free text and identity fields remain outside the abstract scope.

The feedback form records content clarity, level of interactive assistance, and difficulty, with ratings ranging from one to five. Learners can also select the most helpful parts, fill in the most confusing content, add suggestions, and explain their confidence in identification and willingness to recommend. The form fields are focused on teaching evaluation, with name, email, student ID, and password always left outside the form's scope; the ethics instructions are placed on the same page, and the activity boundaries can be seen again at the end of the learning process.

4. Main Content of the Learning Module

Phishing Process

The first topic breaks down the attack process into information gathering, bait creation, identity impersonation, clickbaiting, obtaining credentials or running malicious files, and account abuse. Attackers first look for publicly available information such as courses, departments, and contacts, then embed this information in emails to make the request seem familiar. Learners can understand through the complete process that an email is merely the entry point in the attack chain, with subsequent risks potentially extending to accounts, data, and other contacts.

Sender Impersonation

The second topic compares display names, full email addresses, reply addresses, and spoofed domains. Familiar names easily inspire trust, but true verification relies on the full address and domain. When the reply address is separate from the sender address, attackers can steer subsequent conversations under their control. Individuals can expand the full email header and verify through official contact lists; organizations can use email authentication, external sender alerts, and domain monitoring.

Domains and Links

The third topic explains main domains, subdomains, similar spellings, and extraneous characters. The page also compares the displayed text of links with the actual target and explains that shortened links can conceal the final location. Encrypted connections and lock icons only indicate that the transmission between the browser and the current domain is protected; website ownership and page content still need to be checked separately. Important services should be accessed independently through bookmarks, the school homepage, or known entry points.

Social Engineering Psychology

The fourth topic introduces urgency, fear, authority, reward, curiosity, and familiarity. Attackers use these psychological responses to compress thinking time; users may comply with requests first and then check the address or process. Activities require learners to stop and process emotions and evidence separately; organizations should also establish practices that allow employees to question urgent requests and provide stable verification channels.

Suspicious Attachments

The fifth topic covers web-formatted attachments, compressed files, documents with macros, executable files, and dual extensions. Attachment names and icons can easily lead to misjudgments, and compressed packages may hide the internal file types. Users can first verify the business context, then check the full extension and hand it over to school security tools; organizations can restrict high-risk files, combined with isolated environments, malware detection, and email filtering.

Fake Login Pages

The sixth topic explains how visually similar pages can steal passwords and session tokens. Attackers can replicate school colors and logos, potentially forwarding login processes in real-time and tricking users into approving multi-factor authentication requests. While multi-factor authentication mitigates the risk of a single password breach, real-time phishing can still exploit session or user approval behavior; therefore, domain checks, anti-phishing authentication, session revocation, and login monitoring need to be used together.

Layered Protection

The seventh topic divides controls into prevention, detection, response, and recovery. Prevention includes email filtering, domain protection, multi-factor authentication, least privilege, and training; detection focuses on abnormal logins, reporting channels, and centralized monitoring. After an incident, organizations need to isolate the attack, revoke sessions, inspect devices, and restore accounts, while users are responsible for promptly explaining their actions. This arrangement indicates that security responsibility is shared by individuals and organizations.

Tiered Incident Handling

The eighth topic provides handling methods based on the level of contact. When an email is first received, users can retain the content and verify it through trusted channels; if a link is already opened and the form remains blank, users should close the page, check download history, and report it. Once the password has been submitted, the focus shifts to changing the password through the official portal, revoking the session, checking the authentication method, and notifying the security team. Once the attachment has been opened, the device needs to be stopped from further operation and handed over to technical personnel for inspection and isolation.

5. Interaction, Scoring and Usage

The official mode unfolds in eight progressive steps, with subsequent content only accessible after the pre-test submission. This limitation ensures the pre-test records pre-learning level and maintains a consistent activity order. If a question is missed, the page indicates the missing part; three emails are used to calculate the number of findings, and the best choice is scored for each of the seven defense scenarios. Results are then generated uniformly after the post-test.

The upper right corner of the webpage provides a language switch, which changes the static title, dynamic questions, scenario explanations, form prompts, and scoring text accordingly. When switching languages, the current page, selected answers, and progress remain unchanged. The style file provides different layouts for widescreen, tablet, and mobile devices; the side steps, email area, result cards, and feedback form adjust according to the screen width.

Classroom presentations use a separate demonstration mode. After confirming entry, presenters can directly navigate to Learning, the three scenarios, Defense, Post-Test, Results, and Feedback from the navigation panel. The auto-fill function generates a pre-test score of 4, a post-test score of 9, and example scenario scores, all labeled with demonstration data tags. The demo state only remains in the current running memory and will be cleared when refreshed or exited, while the original production record will be preserved; the reset button will also handle the corresponding state according to the current mode.

6. Security Engineering Analysis

The project first identifies the objects requiring protection, including school accounts, passwords, sessions, personal data, and system access. Phishing attackers may target account control, funds, data, or trusted identities, with entry points distributed across email bodies, links, attachments, login pages, and authentication prompts. Many attacks rely on trust assumptions, such as familiar names representing real identities, school logos representing official pages, and urgent requests representing immediate compliance.

The activity breaks down these assumptions into verifiable evidence. Display names are compared with full addresses, link text with actual domain names, and business requests with normal processes. Learners can see the attacker's intent and corresponding controls by clicking on scenario signals, thus transforming risk analysis from a simple warning into a set of reasoned judgments.

Layered controls are implemented throughout the project. Prevention aims to reduce attack opportunities; email authentication, filtering, domain protection, and least privilege are all implemented at this layer. Detection relies on reporting, abnormal login monitoring, and centralized analysis. Response is responsible for limiting current damage, while recovery addresses account, session, device, and business continuity. Individual judgment is one layer; complete protection also relies on technical setup and organizational processes.

7. Testing and Learning Outcome Evaluation

The current project has passed browser workflow checks. All ten pre-tests and ten post-tests can be selected and submitted; missed answer prompts appear; all three emails can be completed and scores are provided; and explanations are displayed for the seven defense checks. Step progress, bilingual switching, formal mode restrictions, demo navigation, result clearing, and activity reset have

all been checked; the browser console check result is passed, and page request records remain local.

During testing, it was found that the hidden state of the completion prompt area was covered by style rules, causing the page to prematurely display part of the completed content. The project confirmed the result by adding explicit hidden style rules and re-running the workflow. Responsive layout was also checked under different screen widths; on narrow screens, navigation and content are arranged vertically, and email explanations and result cards remain readable.

Real participant evaluation is scheduled for the next stage. The plan is to first confirm the workflow with the course instructors, then invite beginners aged 18 and above to participate voluntarily. Participants will use anonymous IDs to complete the pre-tests, learning activities, post-tests, and feedback. The evaluation compares the same participant's scores before and after, reviewing three inspection scenarios, seven defense judgments, topic errors, confidence scores, and written suggestions. A post-test explanation clarifies the exemplary nature and purpose of the materials.

Several limitations need to be noted regarding the evaluation. Convenient sampling narrows the applicability of conclusions; the two sets of questions use different scenarios, and their difficulty should be compared in real-world use. The post-test follows the learning activity, and the results primarily reflect short-term mastery; confidence scores are also self-reported. The project will incorporate these factors into the final analysis and adjust questions, explanations, and page operations based on areas where participants are prone to misunderstanding.

8. Technical Implementation and Local Data Processing

The website is built using web markup, cascading styles, and scripting languages. All files can be run directly from the same folder. Content and page controls are stored separately. Questions, learning topics, scenarios, and defense judgments are generated uniformly by scripts, and language tables handle the corresponding conversions of static content. This structure allows for centralized maintenance of new content and reduces the chance of discrepancies between the two language versions.

The final progress is saved in the browser session store, including question selections, scores, scenario discovery, and defense answers. Feedback text remains only on the current tab, and downloaded summaries only compile anonymous grades and question results. The website uses local files for all interactions; network requests and external interfaces are outside the system scope. Email links only trigger explanations, and attachments only display text and graphics.

The results page provides local record cleanup, and the start page offers a complete activity reset. The presentation mode uses a separate temporary state; the official state is saved first and then restored when exiting the presentation. This approach resolves the issue of classroom presentations potentially overwriting official grades and allows presenters to quickly access any page.

9. Ethical and Safety Scope

All emails, institution names, addresses, and individuals use fictitious content, and domain names use dedicated sample or test suffixes. Links on web pages remain local buttons, attachments remain static, and login requirements are only used for risk disclosure. School emails, real accounts, and actual systems remain outside the active scope, and classroom presentations only show pre-prepared fictitious scenarios.

Data processing uses minimal scope. Forms only record teaching evaluations, official grades remain in the current browser session, and anonymous summaries exclude free text and identity fields. Participants must give their consent before testing, and can opt out and request the removal of any anonymous records. Reports will only use summarized results, and classroom examples will always be labeled as demonstration data.

The activity emphasizes support and timely reporting. In case of user errors or credential leaks, the system will provide recovery steps and prompt the organization to provide assistance. This approach reduces blame, encourages participants to explain situations promptly, and allows the security team to address account and device risks earlier.

10. Project Progress and Problem Solving

The first phase completed the basic webpage, with five questions each for the pre- and post-tests, and added a mock email, basic defense suggestions, and a feedback page. This version demonstrated the main directions, but the teaching scope was narrow, and security analysis and effectiveness measurement were relatively simple.

The second phase expanded the two tests to ten questions each, with each question corresponding to a learning objective. The learning module subsequently increased to eight topics, expanding from warning signs to attack processes, trust issues, organizational control, and incident handling. The results page also added topic performance and review suggestions, allowing learners to see specific weaknesses.

The third phase added three emails and seven defense scenarios, and bilingual content was also completed in this phase. For classroom presentations, the project later added a presentation mode, quick navigation, and temporary grades; the official progress and presentation status were managed separately, allowing for free navigation during class. The project also completed process checks, responsiveness checks, and console checks, and corrected the issue of premature completion prompts.

11. Tool Use and Personal Responsibility

The generative AI tool was involved in the initial code drafting, content expansion, text modification, testing assistance, and presentation material preparation. Students are responsible for selecting phishing topics, identifying target audiences and learning objectives, and reviewing security content; system testing, limitation analysis, collection of evidence from real participants, and final reflection are also completed by students.

The current reflection log retains the facts of each stage and includes sections for recording personal learning, problems encountered, and changes after testing. After the real participant testing, students are required to complete these sections based on the actual process, drawing from their own observations and understanding of the course. In-class provisional grades only apply to the demonstration page effects; the final report's grades and feedback will use the actual records.

12. Current Limitations and Next Steps

The main limitation at this stage stems from the lack of evidence regarding teaching effectiveness. Functionality checks have proven that the webpage flow and scoring system work, and real participant testing will further demonstrate whether the content is helpful to beginners. The pre- and

post-test scenarios have been separated, but the difficulty relationship between the two sets of questions still needs actual data support; a delayed test could be added later to check the retention of learning content over a period of time.

The next step is to conduct a small-scale trial, focusing on observing question comprehension, navigation operations, and scenario explanations. Based on the trial results, misunderstanding-prone text will be revised, followed by a main evaluation, and paired scores and anonymous feedback will be compiled. Finally, the reflection record, presentation slides, and report will be updated, clearly stating the actual results, limitations, and reasons for modifications.

Conclusion

The project currently has a complete webpage, classroom demonstration, and testing plan. The evaluations from real participants move to the next stage, and the relevant evidence will determine whether the activity has achieved its teaching objectives and will also support subsequent modifications. The project's final message is straightforward: phishing exploits people's trust in identities and processes, and security work requires preparation from individuals, technology, and organizations working together.

Link: [q726785074-creator/COMP6441-Project: COMP6441 cybersecurity project](https://github.com/q726785074-creator/COMP6441-Project:COMP6441_cybersecurity_project)